PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Attaques DDoS et protection

03-270 ANSSI - Dénis de service distribués DDoS — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Les attaques DDoS se classent en trois types : volumétriques pour la bande passante, protocolaires ou applicatives pour les ressources CPU ou RAM.
2. La protection peut être assurée par un service dédié protégeant les niveaux 3, 4, 5 et 7 du modèle OSI.
3. Une attaque DDoS bruyante peut servir de rideau de fumée pour dissimuler une attaque plus discrète et plus grave menée simultanément.

Les attaques DDoS

Notion	À retenir
Types d'attaques	**Volumétriques** : bande passante (**UDP/ICMP flood**) ; **protocolaires** : CPU/RAM via un protocole (**SYN/TCP flood**, **Smurf**) ; **applicatives** : CPU/RAM via un service (**DNS water torture**).
Adaptabilité	Techniques **non exclusives** : les attaquants peuvent **adapter** ou **combiner** les types d'attaques (ex: passer de **volumétrique** à **protocolaire**).

Recommandations de protection DDoS

Notion	À retenir
Restriction et service anti-DDoS	Restreindre les services au **strict besoin opérationnel**. Acquérir un service dédié (via **FAI**, **hébergeur** ou **fournisseur professionnel**) protégeant les niveaux **3, 4, 5 et 7** du modèle OSI.
Architecture résiliente	Répartir la charge (**sous-systèmes**, **centres de données**, **répartiteurs de charge**). Garantir l'administration via un **réseau dédié** et l'isolation des services via des **chaînes d'accès** ou **hébergeurs distincts**.
Filtrage et pare-feux	Pare-feu en coupure : filtrage **niveaux 3 et 4** uniquement, désactiver le filtrage applicatif, réduire **UDP** et prévoir le retrait du **suivi de connexions**. Pare-feu applicatif en aval pour les sites web.

Détails de la mise en œuvre

- **Service anti-DDoS** : peut être mis en œuvre via **trou noir**, **dépollution des flux** ou **déroutement BGP**.
- **Fonctions anti-DDoS** : incluent le **contrôle de débit**, la **limitation du nombre de requêtes**, la **protection anti-robot** et la **reconnaissance d'IP malveillantes**.
- **Dimensionnement architecture** : doit tenir compte des **besoins métiers fluctuants**, de la **bande passante**, de la **puissance de calcul** et de la **capacité de stockage**.
- **Protection sites web** : possible via un **CDN** pour la répartition de charge, avec une vigilance sur la **confidentialité** (ressources potentiellement à l'étranger).
- **Pare-feu applicatif** : doit être configuré en aval pour ajuster les **limites de session** et bloquer les **requêtes malveillantes**.

Anticipation et réaction face aux DDoS

Notion	À retenir
Supervision et détection	Mettre en place un dispositif de détection précoce, un **centralisateur de journaux** pour le diagnostic et une **procédure testée régulièrement** avec les prestataires.
Mode dégradé et inventaire	Prévoir un **mode dégradé** pour les activités critiques (le **FAI** peut l'imposer si **sa propre infrastructure** est attaquée) et réaliser un **inventaire régulier** des services ouverts sur Internet.
Gestion de crise et alertes	Mettre en place une gestion de crise avec **prestataires DDoS** et **responsables communication** ; contrôler les **alertes annexes** (signes d'attaques plus discrètes).

Pièges et confusions

⚠ Croire qu'une attaque DDoS ne peut pas servir de rideau de fumée pour une autre attaque plus discrète.
⚠ Oublier que le recours à un CDN pour la résistance aux attaques DDoS n'est pas neutre en confidentialité.
⚠ Négliger de contrôler les autres alertes de sécurité générées pendant un incident DDoS.

Sigles et définitions

DDoS	Attaque en disponibilité menée depuis de multiples sources contre une cible.
Attaque volumétrique	Type de DDoS visant à épuiser la bande passante réseau disponible.
Attaque protocolaire	Type de DDoS visant à épuiser les ressources CPU ou RAM en détournant le fonctionnement d'un protocole.
Attaque applicative	Type de DDoS visant à épuiser les ressources CPU ou RAM en détournant le fonctionnement d'un service.
CDN	Réseau de distribution de contenu permettant de répartir la charge sur un grand nombre de serveurs.
Blackholing	Technique de dépollution des flux mise en œuvre par les fournisseurs d'accès ou de services.

Auto-test

1. Quels sont les exemples d'attaques volumétriques ?
2. Quel est l'objectif d'une attaque DNS water torture ?
3. Quelles techniques permettent la dépollution des flux ?
4. Où doit être configuré le pare-feu applicatif ?
5. Que doit-on prévoir pour les activités critiques en cas d'attaque ?

Réponses : **1.** UDP flood ou ICMP flood. · **2.** Épuiser les ressources CPU ou RAM en détournant le fonctionnement d'un service. · **3.** Le trou noir ou le déroutement BGP. · **4.** En aval pour les sites web. · **5.** Un mode dégradé.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.